

Dispute Chamber

Substantive Decision 171/2024 of December 19, 2024

File Number: DOS-2022-02016

Subject: Breach related to personal data concerning a registration system

The Dispute Chamber of the Data Protection Authority, composed of Mr. Hielke HIJMANS, chair, and Messrs. Frank De Smet and Dirk Van Der Kelen, members;

Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation), hereinafter referred to as "GDPR";

Considering the law of December 3, 2017, establishing the Data Protection Authority, hereinafter referred to as "WOG";

Considering the internal rules of procedure, as approved by the House of Representatives on December 20, 2018, and published in the Belgian Official Gazette on January 15, 2019;

Considering the documents of the file;

Has made the following decision regarding:

The respondent:

Local Consultation Platform Ghent Secondary Education, King Albert II Avenue 15, 1210 Brussels, hereinafter referred to as "the respondent".

Substantive Decision 171/2024 — 2/27

I. Facts and Procedure

1.

Following the handling by the General Secretariat of the GBA of the data breach that occurred at the respondent on May 4, 2022, the file was investigated by the General Secretariat and forwarded to the Executive Committee for referral to the Inspection Service.

2.

On June 20, 2022, the Executive Committee of the Data Protection Authority (hereinafter "GBA") decided to initiate a case with the Inspection Service of the GBA based on Article 63, 1° WOG¹ as it was applicable at the time of the facts that gave rise to the present procedure (hereinafter referred to as WOG) since the Executive Committee was of the opinion that there were serious indications pointing to a practice that could lead to a breach of the fundamental principles of personal data protection. The elements that the Executive Committee took into account included, among others, the number of individuals involved, the vulnerable nature of these individuals, the processing of particularly sensitive data (such as the national register number and the indication of whether these individuals can be classified as indicator students), the apparent absence of a data protection impact assessment (hereinafter: DPIA), the apparent absence of an adequate procedure for following up on reports of a security issue/data breach, the lack of logs regarding the downloading of lists of registered children, the failure to meet certain elements required for notifying a breach related to personal data to the individuals concerned, and the fact that there was no transparent privacy statement available on the website where students are to be registered.

3.

The reason for the aforementioned initiation was a concrete data breach at a processor managing the platform MeldJeAan in the context of the registration procedure for Ghent secondary schools, whereby parents could register their children for a secondary school in Ghent. Parents could register their child during the period from March 21 to April 22, 2022. Subsequently, lists of the children who registered for the school are compiled per school. After logging into the back office of 'MeldJeAan' by a staff member of a school, this person can download a list for their school containing all personal data of the parents and their children who register at that school. Due to an error in the online application, it turned out that the URL with the link to that download list was also directly accessible without logging in. Each secondary school has a unique ID of 30 characters in the system that is included in the

Article 63, 1° (then) WOG:

Art. 63. The initiation with the inspection service can occur:

1° when the executive committee establishes serious indications of the existence of a practice that may lead to a breach of the fundamental principles of the protection of personal data, in the context of this law and of the laws that contain provisions regarding the protection of the processing of personal data.

Decision on the Merits 171/2024 — 3/27

URL. If one had access to 1) the complex URL of the download list and 2) the unique ID of another secondary school, one could download a list containing personal data of the parents and their child enrolled at that school without first logging in. Someone reported this procedure to the press, and at least one (pseudonymized) list was made known to the press in this manner. The pseudonymized list that was leaked to the press belongs to one school associated with the respondent.

4.

On October 10, 2022, the investigation by the Inspection Service is concluded, the report is added to the file, and the file is forwarded by the Inspector General to the Chair of the Disputes Chamber (Article 91, § 1 and § 2 WOG). The report contains findings regarding the subject of the decision of the Executive Committee, as well as findings that go beyond the subject of the aforementioned decision of the Executive Committee and concludes that there is a violation of the following articles:

1.

Article 5.1, f) and 5.2, Article 24.1, Article 25.1, Article 32.1 and 32.2 of the GDPR;

2. Article 33 and Article 34 of the GDPR;

3. Article 35.1, 35.2, 35.3 and 35.7 of the GDPR;

4. Article 38.1 and Article 39 of the GDPR;

5. Article 30.1, Article 30.3 and Article 30.4 of the GDPR.

5.

On June 28, 2024, the Disputes Chamber decides based on Article 95, § 1, 1° and Article 98 WOG that the file is ready for substantive treatment.

6.

On June 28, 2024, the involved party is notified by registered mail of the provisions as mentioned in Article 95, § 2, as well as those in Article 98 WOG. He is also notified based on Article 99 WOG of the deadlines to submit his defenses.

The deadline for receipt of the respondent's response was set for August 26, 2024.

7.

On July 3, 2024, the respondent electronically accepts all communication regarding the case.

8.

On August 26, 2024, the Disputes Chamber receives the response from the respondent. The respondent outlines the context in which the registration procedure was established. The respondent then addresses the question regarding the ambiguity that existed about who the data controller is in the context of the registration procedure. Finally, the respondent discusses the closure of the data leak and the consequences that were given to the incident, what additional security measures were taken, and what actions he has undertaken to comply with the provisions of the GDPR.

9.

On October 23, 2024, the respondent is informed that an official hearing will take place on November 27, 2024.

10.

On November 27, 2024, the respondent is heard by the Disputes Chamber.

11.

On December 5, 2024, the minutes of the hearing are presented to the respondent.

12.

On December 12, 2024, and December 13, 2024, the Disputes Chamber receives some comments from the respondent regarding the minutes, which it decides to include in its deliberation.

II. Justification

II.1. Identity of the Data Controller

13.

The question arises whether the respondent should be considered the data controller in the context of the registration procedure. This question is important because the data controller responsibilities and obligations arising from the GDPR differ depending on the role in which the involved actors operate in the context of a processing activity. To comply with these obligations, it is therefore necessary that there is clarity about everyone's role and the corresponding obligations prior to the processing of personal data.

14.

The respondent states that according to the Flemish Agency for Education Services (hereinafter: AGODI), the school boards were the data controllers in the context of the registration procedure. However, this position was not unanimously shared by the various actors involved in the registration process. During the hearing, the respondent reiterates his position that there were different views regarding the data controller's responsibility in the context of the registration system and that these questions were not resolved at the time of its implementation. The Disputes Chamber therefore finds that there was considerable ambiguity regarding the identity of the data controller in the context of the registration procedure for secondary education in Ghent, where the aforementioned data leak occurred.

15.

To determine the identity of the data controller, the Disputes Chamber refers to Article 4.7 of the GDPR, which defines the data controller as follows: the "natural person or legal entity, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data."

Decision on the merits 171/2024 — 5/27

establishes the processing of personal data." The analysis of the identification of a data controller requires a factual assessment.³

16.

Consequently, the Dispute Chamber must ascertain whether the respondent actually determines the purpose and means for the processing of personal data regarding the enrollment right (i.e., the registration procedure).

17.

The Dispute Chamber notes that Article 253/2 of the Secondary Education Code of December 17, 2010⁴ defines the joint objectives as follows: "The joint objectives of the enrollment right as an instrument of a policy for equal educational opportunities are:

- ensuring the free school choice of the persons and students involved;
- realizing optimal learning and development opportunities for all students;
- promoting social cohesion;
- avoiding exclusion, segregation, and discrimination."

18.

As a general rule, school boards can determine whether or not to use the registration procedure as prescribed by the Secondary Education Code. Notwithstanding this, the Flemish Government may delineate capacity areas based on impending or existing capacity problems, where school boards are then required to jointly organize a registration procedure for all their schools or locations situated in these areas. The Flemish Government has provided for two capacity areas, including the operational area of the Local Education Platform Ghent (LOP Ghent).⁵ In a LOP, representatives from all schools in a municipality or region meet along with their partners: Centers for Student Guidance (CLB), parents and students, local partners, organizations of migrants and the poor, integration centers,

³ EDPB Guidelines 07/2020 on the concepts of "data controller" and "processor" in the GDPR, July 7, 2021,

https://edpb.europa.eu/system/files/2023-10/edpb_guidelines_202007_controllerprocessor_final_nl.pdf, paragraph 52.

⁴ B.S. June 24, 2011.

⁵

Secondary Education Code, available at

<https://data-onderwijs.vlaanderen.be/edulex/document.aspx?docid=14289#301966>.

Art. 253/7: § 1. A school board decides annually and no later than [6315 November63] per school, per location, or per structural component, whether it wishes to be able to refuse students for the following school year due to reached capacity. In the affirmative case, the provisions of subsection 3 apply; in the other case, the provisions of subsection 2 apply. Even if the school board decides not to refuse due to capacity for the following school year, it may join a registration procedure. In that case, the provisions of subsection 3 shall apply.

[51...51]

§ 2. The Flemish Government may, notwithstanding paragraph 1, delineate capacity areas based on impending or existing capacity problems [63...63], whereby the right to enrollment mentioned in Article 253/3 can no longer be guaranteed. In capacity areas, school boards are required to jointly organize a registration procedure for all their schools and locations situated in the capacity area. Notwithstanding what is stated in paragraph 1, the capacity areas from the registrations for the school year] are: the operational area of LOP Antwerp and LOP Ghent.

Decision on the Merits 171/2024 — 6/27

Reception offices for newcomers and school development work.6 A Local Education Platform (LOP) has, among other tasks, the responsibility to make agreements regarding the pursuit of objectives related to equal opportunities, to make arrangements concerning the communication about the enrollment policy of the schools and its alignment with the communication from the Flemish government, and to make agreements regarding the application of priority in the context of the enrollment policy. The Secondary Education Code establishes the criteria based on which school assignments are made, although a local education platform (LOP) or a school board may grant certain priority to specific parameters to meet the aforementioned objectives of the registration procedure.7 19.

In short, within the LOP, the school boards, together with local (education) partners, make agreements regarding the registration procedure, but the enrollment or refusal of students is carried out by the school boards themselves based on the legally defined objectives.

20. Regarding the resources, the respondent explains that the personal data collected and the stakeholders from whom this data is collected in the context of the registration procedure are determined by law. Additionally, the school boards choose which software or registration system will be used for the registration procedure. They decide this either individually or through agreements made within the LOP (as is the case here). The respondent has decided to use the registration system MeldJeAan as it has been used for many years by LOP Antwerp and is considered a robust system. However, the funding for the use of such software for the registration procedure exceeds the financial resources of the respondent. The Flemish government grants a subsidy in this context, but since this is insufficient, the City of Ghent has allocated additional resources.

21.

In light of the above, the Disputes Chamber concludes that at the time of the data breach, there was much uncertainty among the involved actors regarding who should assume the role of data controller, and that this uncertainty existed even at the commencement of the registration procedure. However, the Disputes Chamber finds that the respondent neither determines the purpose nor the essential means of the processing. The objectives are, after all, defined by law, and the means are determined by the

6 Art. VIII.4 of the Decree of October 29, 2016, of the Flemish Government concerning the codification of certain provisions for education, B.S. December 29, 2018.

7 Art. 253/15 Secondary Education Code: § 1. A school board may choose to grant priority for one or more of its schools for a certain capacity as mentioned in Article 253/13, to one or more underrepresented groups, being one or more groups of students who, based on one or more objective characteristics, [76are relatively underrepresented in the school compared to a reference population, whereby, deviating from this principle, students with an IAC report or OV4 report in a regular school may always be considered as an underrepresented group, regardless of the reference population.76]

[63]The priority is applied until a maximum of 20% of the specified capacity is occupied by students belonging to one or more underrepresented groups. Even in the case of multiple underrepresented groups, the priority is a maximum of 20% of the specified capacity mentioned in Article 253/13.

Decision on the Merits 171/2024 — 7/27

school boards within the contours of the Codex Secondary Education. The registration procedure is primarily financed by the City of Ghent and additionally by the subsidy from the Flemish government. The Dispute Chamber therefore believes that the defendant does not play an essential role in determining the purpose and means of the processing of personal data in the context of the registration procedure, which means that it cannot be considered a data controller.

22.

The Dispute Chamber points out that sensitive personal data is processed on a large scale in the context of the registration procedure. It must therefore be clear in advance to all actors who is responsible for what. According to Article 6.3 GDPR, however, “the purpose of the processing must be established in that legal basis [or] must be necessary for the performance of a task carried out in the public interest or for the exercise of public authority vested in the data controller.” Furthermore, according to Article 6.3 GDPR, the legal basis may also “contain specific provisions to adapt the application of the rules of this regulation, including the general conditions regarding the lawfulness of processing by the data controller; the types of processed data; the data subjects; the entities to whom and the purposes for which the personal data may be disclosed; the purpose limitation; the retention periods; and the processing activities and procedures (...).”

23.

In this regard, the Dispute Chamber points out that according to the aforementioned Article 6.3 GDPR, read in conjunction with Article 22 of the Constitution and in light of Articles 7 and 8 of the European Charter of Fundamental Rights, a legislative norm must establish the essential characteristics of data processing that is necessary for the execution of a task carried out in the public interest or for the exercise of public authority entrusted to the data controller.⁸ The Dispute Chamber emphasizes that the processing in question must be framed by a norm that is sufficiently clear and precise, the application of which is foreseeable for the persons involved. According to Article 6.3 GDPR, the precise purpose(s) of the processing must be included in the legal norm itself. Furthermore, the following elements must be foreseeable: the identity of the data controller(s), the categories of processed data, provided that these comply with Article 5.1 GDPR, “adequate, relevant and limited to what is necessary for the purposes for which they are processed,” the categories of data subjects whose data will be processed, the retention period of the data, the recipients or

⁸ See also the opinions of the Knowledge Center of the GBA 36/2020, 42/2020, 44/2020, 46/2020, 52/2020, and 64/2020

(https://www.gegevensbeschermingsautoriteit.be/burger/zoeken?q=&search;_category%5B%5D=taxonomy%3Apublication&search;_type%5B%5D=advice&s=recent&l;=25)

Decision on the Merits 171/2024 — 8/27

categories of recipients to whom their data are disclosed, the circumstances in which and the reasons for which they will be disclosed, and any limitation of the obligations and/or rights mentioned in Articles 5, 12 to 22, and 34 GDPR.

24.

In this regard, the Dispute Chamber points out that tasks of public interest or public authority with which data controllers are charged are often not based on precisely defined obligations or legislative norms that meet the requirements mentioned in paragraph 23, particularly the establishment of the essential characteristics of data

processing. Rather, processing occurs based on a more general authorization to act, as necessary for the performance of the task. This leads to the relevant legal basis often lacking concretely defined provisions regarding the necessary data processing in practice. Data controllers who wish to rely on Article 6.1 e) GDPR based on such legal basis must then make their own assessment between the necessity of the processing for the task of public interest and the interests of the data subjects. The involved actors should therefore have determined who has the role of data controller before implementing the registration procedure so that they can comply with the obligations mentioned above. The Dispute Chamber reiterates the large-scale nature of the processing of personal data of (primarily) children.

25.

In light of the data breach in question, the issue of data controller responsibility for the processing in the context of the registration procedure was examined more closely. In the meantime, there is more clarity regarding the data controller. With the education decree XXXIV of April 19, 2024, it has been included in the Codex Secondary Education from September 1, 2024, that: "For the organization, allocation, and refusal of registered students, the school board is the data controller. In the case of processing by a LOP, the school board or the mandated party remains the data controller." The Flemish government also provides an online registration system for schools. For this registration system, the school boards and AGODI are joint data controllers. The school boards and AGODI jointly determine the purpose and means for the processing of personal data. Both are responsible in that case for maintaining and processing personal data in the context of the GDPR.

9 B.S. June 28, 2024

Decision on the Merits 171/2024 — 9/27

II.2. Article 5.1, f) and 5.2 of the GDPR, Article 24.1 of the GDPR, Article 25.1 of the GDPR, and Article 32.1 and 32.2 of the GDPR

26.

The Inspection Service establishes that the respondent has committed a breach of Article 5.1, f) and 5.2 of the GDPR, Article 24.1 of the GDPR, Article 25.1 of the GDPR, and Article 32.1 and 32.2 of the GDPR.

27.

Article 5.1.f) of the GDPR stipulates that "[personal data] shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by taking appropriate technical or organizational measures."

28.

In further elaboration of Article 5.1.f) of the GDPR, Article 32.1 of the GDPR states that the respondent, as the data controller, must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk. This must take into account the state of the art, the costs of implementation, as well as the nature, scope, context, purposes of processing, and the likelihood and severity of the various risks to the rights and freedoms of individuals.

29.

Article 32.2 of the GDPR provides that, in assessing the appropriate level of security, account must be taken of the risks associated with processing, particularly as a result of the destruction, loss, alteration, or unauthorized disclosure of, or unauthorized access to, personal data transmitted, stored, or otherwise processed, whether accidentally or unlawfully.

30. The Dispute Chamber points out that the accountability obligation under Article 5.2 of the GDPR, Article 24.1, and Article 25.1 of the GDPR entails that the data controller has the obligation to, on the one hand, take proactive measures to ensure compliance with the provisions of the GDPR and, on the other hand, to demonstrate that it has taken such measures.

31.

In summary, a data controller has the obligation to take appropriate technical and organizational

measures to ensure an appropriate level of security and to be able to demonstrate this.

32.

As already mentioned, the Inspection Service found breaches regarding the above obligations. The Inspection Service refers to the Inspection Investigation and states that the respondent has not clarified the following points:

- a) when exactly the measures in the document “Appendix 3 Overview of Additional Security Measures” of the respondent were discussed, approved, and implemented, and who was involved;
 - b) why there are no signatures for the respondent in the processing agreement with the processor Z3;
 - c) how and when the compliance with the processing agreement with the processor Z3 was monitored by the respondent;
 - d) how and when the data protection officer of the respondent was involved in the context of the security of the processing of personal data in the context of the online registration system ‘MeldJeAan’.
- The respondent states in the document “Appendix 3 Overview of Additional Security Measures” on the one hand that no data protection officer has been designated for the respondent as such, but on the other hand that the respondent, in consultation with the data protection officers of the schools affiliated with the LOP, decided to make a report to the VTC. The respondent could indeed rely on the information and advice of a data protection officer, but has insufficiently done so here.

33. In its conclusions, the respondent argues that at the time of the launch of the application for the registration system for secondary education in Ghent, i.e., the software MeldJeAan, measures were taken to mitigate the risks of breaches of the rights and freedoms of the data subjects. However, the application MeldJeAan had already been developed and put into use some time earlier for registration for education in Antwerp and primary education in Ghent. However, the circumstances at the time of the initial development of the application were completely different. The subject of (cyber)security was not as current then as it is now, the respondent argues.

34. The respondent then responds to the above-mentioned points from the Inspection Service.

35. Regarding the above point a), the respondent argues that the school boards and their data protection officers were immediately involved following the aforementioned data breach. The additional security measures were consistently discussed internally at the respondent, at preparatory meetings and at the working groups in which the school boards are represented, specifically at the meeting of September 15, 2022, where all additional measures were discussed. The respondent provided the minutes of this meeting. This point was also discussed at the General Meeting of the respondent, of which the involved school boards are members and/or for which they are invited, and specifically at the meeting of October 20, 2022. The minutes of this meeting were also submitted to the Dispute Chamber by the respondent. The measures discussed in the above meetings were included in the GEB, which was emailed on March 20, 2023, to the representatives of the school boards with the aim of...

Decision on the merits 171/2024 — 11/27

to submit this to their school board and the data protection officer for feedback. Based on the feedback received, the GEB was finalized.

36. Regarding the above point b) and the question of why there are no signatures from the respondent in the processing agreement with Z3, the respondent clarifies that he entered into a processing agreement with Z1 Gent (now District 09), an autonomous municipal company responsible for executing municipal policy tasks. This processing agreement has specified all aspects of telematics within the framework of the processing agreement. The processing agreement between Z1 and Z3, to which the Inspection Service refers, should be considered a sub-processing agreement under the processing agreement between the respondent and Z1. Consequently, there is no signature from the respondent on that sub-processing agreement.

37. At the time of the data breach, the respondent took the initiative to conclude a new processing agreement with Z1 (now: Z2) on behalf of (i) the involved school boards and (ii) to ask AGODI for clarification regarding the identity of the data controller in the context of the registration system. Based on the provision recently included in the secondary education code, it is clear that a processing agreement must be concluded between the school boards as joint data controllers and the processor. The respondent states that this will be further incorporated in this manner.

38. Regarding the above point c) and the question of how and when the compliance with the (sub)processing agreement between Z1 (now: District 09) and Z3 was monitored by the respondent, the respondent reminds that the (main) processing agreement was concluded between himself and Z1. Z1, in turn, entered into a sub-processing agreement with Z3. Consequently, the respondent argues, Z3, as a sub-processor, is contractually obligated to correctly execute the sub-processing agreement with Z1. According to the clause "Processing by subcontractors" in the (main) processing agreement, only new subcontractors could be engaged with prior written consent from the contracting authority, in order to ensure adequate data protection. After the incident, Z1, in its role as processor, took the initiative to elevate the security of personal data processing in collaboration with Z3, the sub-processor. This was achieved by conducting penetration tests and security audits on the systems used, implementing multi-factor authentication (MFA) for a category of users, and introducing GDPR-10 With the education decree XXXIV of 19/04/2024, B.S. 28/06/2024, it has been included in the secondary education code from September 1, 2024, for regular secondary education: "For the organization, allocation, and refusal of registered students, the school board is the data controller. In the case of processing by a LOP, the school board or the mandated party remains the data controller." Decision on the merits 171/2024 — 12/27

audit logging. Z1 has monitored these initiatives through periodic meetings and email exchanges. The complete list of measures is documented in the GEB under the chapter "Technical and Organizational Measures."

39. Regarding the above point d) and the question of how and when the data protection officer of the defendant was involved in the security of the processing of personal data within the framework of the online registration system 'MeldJeAan', the defendant argues that no data protection officer was appointed for him as such. This is related to the position taken that the school boards are the data controllers for the registration system and thus not the LOP. Following the incident, the data protection officers of the school boards were immediately involved. They are also further involved in the follow-up through the school boards.

40. As also acknowledged by the defendant, there is indeed a breach concerning personal data (the aforementioned data leak). As far as necessary, the Disputes Chamber reminds that a breach concerning personal data constitutes a security breach that accidentally or unlawfully leads to the destruction, loss, alteration, or unauthorized disclosure of or unauthorized access to transmitted, stored, or otherwise processed data. By downloading the lists, third parties could also consult the personal data of the individuals involved. There is therefore a breach of confidentiality, namely an unauthorized or unintended disclosure of or access to personal data. The personal data in question were inadvertently accessible to and exposed to external persons for a period, thereby compromising confidentiality.

41. The Disputes Chamber notes that the defendant does not deny the consequences of the data leak for the individuals involved. Furthermore, the data leak could not have occurred accidentally. There was a deliberate action with the necessary knowledge required. As the defendant also points out, the data leak led to the release of information, but in no case to breaches of the integrity or accessibility of the information. Only a limited number of persons have access to the data, and they are expected, by virtue of their position, to use the data solely for the performance of their duties and to ensure the confidential nature of the personal data and its security.

42. As the defendant also points out, the Disputes Chamber judges that misuse, even among its own employees, cannot be ruled out. However, the Disputes Chamber is of the opinion that too few technical and organizational measures were taken to minimize that risk of misuse as much as possible, such as a logging system and multi-factor authentication, or awareness actions for staff to make them aware of the fundamental principles of data protection and the obligations arising from the GDPR.

43. Following the incident, a number of additional technical security measures were implemented. The Disputes Chamber notes that various security tests were conducted and various software measures, access measures, and environmental measures such as logging and two-factor authentication were implemented. Additionally, since the incident, all employees and management responsible for processing personal data via the registration system must explicitly agree to the confidentiality

declaration and code of conduct in the context of registration, in addition to the already applicable school-specific measures. Furthermore, more clarity has been provided in the Codex Secondary Education regarding the identity of the data controller (see supra part II.1). Meanwhile, within the LOP Gent, the decision was made to work with the registration system developed by the Flemish government (see supra part II.1).

44. The documents added by the defendant to the file have enabled the Disputes Chamber to gain insight into the forward-looking approach of the defendant to prevent a recurrence of the events as they occurred.

45. This leads the Disputes Chamber to conclude that there has been a historical breach of Article 5.1, f) and 5.2 of the GDPR, Article 24.1 of the GDPR, Article 25.1 of the GDPR, and Article 32.1 and 32.2 of the GDPR, but that this is not attributable to the defendant since he is not the data controller for the disputed processing activities.

II.3. Articles 33 and 34 of the GDPR

46. The Inspection Service establishes in its investigation report on the one hand a breach of Article 33 GDPR because the defendant did not report the breach concerning personal data (namely the aforementioned data leak) to the GBA and on the other hand a breach of Article 34 GDPR because the notification of the breach to the individuals concerned regarding personal data was not done without delay.

47. A breach concerning personal data as defined in Article 4, 12° GDPR is "a breach of security that accidentally or unlawfully leads to the destruction, loss, alteration, or unauthorized disclosure of or unauthorized access to transmitted, stored, or otherwise processed data."

48. When such a breach concerning personal data occurs, the GDPR imposes on the data controller the obligation to notify the competent national...

Decision on the merits 171/2024 — 14/27

supervisory authority and, in certain cases, to notify the individuals whose personal data is affected by the breach.

49. Regarding the notification of the breach related to personal data to the supervisory authority, the Dispute Chamber refers to Article 33 GDPR, which states that "In the event of a personal data breach, the data controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, no later than 72 hours after having become aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. Where the notification to the supervisory authority is not made within 72 hours, it shall be accompanied by reasons for the delay."

50. Regarding the notification of the data breach to the supervisory authority pursuant to Article 33 GDPR, the respondent argues in his conclusions that he reported the data breach to the Flemish Supervisory Commission (VTC) on May 6, 2022. He bases this on the website of the VTC, which states the following:

"The Flemish Supervisory Commission (VTC) is the supervisory authority responsible for overseeing the application of the General Data Protection Regulation (GDPR) by the Flemish administrative bodies.

Reporting a data breach

As of May 25, 2018, there is an obligation to report data breaches. This obligation means that Flemish authorities must notify the Flemish Supervisory Commission within 72 hours and without undue delay as soon as there is a risk to the fundamental rights and freedoms of the individuals concerned (the people whose personal data are involved). Sometimes they must also inform the individuals themselves about the data breach."

51. The respondent therefore asserts that he believed he had fulfilled his obligations by notifying the VTC and takes note of the explanation regarding this in the report of the inspection service.

52. The Dispute Chamber will first examine whether the breach related to personal data should have been reported to the GBA or to the VTC pursuant to Article 33.1 GDPR.

53. From the perspective of European Union law, it is clear that the Data Protection Authority is a supervisory authority within the meaning of Article 8.3 of the Charter of Fundamental Rights of the

European Union and in the sense of Chapter VI of the GDPR. The Dispute Chamber further points out that the EU treaties, as well as the case law of the Court of Justice of the European Union, impose strict requirements on the independence and performance of duties of the supervisors. Supervision is an essential part of the rights of individuals.

Decision on the merits 171/2024 — 15/27

on the protection of their personal data.¹¹ In other words, individuals have a right to protection by an authority. Part of that right consists of having a complaint handled appropriately by the authority.¹² The Dispute Chamber points out that the Constitutional Court has established the following: “There is no evidence that the Flemish Supervisory Commission for the processing of personal data has been registered with the competent institutions of the European Union and that a procedure has been established to ensure that it complies with the rules related to the coherence mechanism referred to in Article 63.”¹³ It follows from this that, at least at the time of the data breach in question, the VTC was not competent to take note of the notification of the breach concerning personal data in accordance with Article 33 GDPR.

54. As far as necessary, the Dispute Chamber refers in this context to the Guidelines for the notification of personal data breaches under Regulation 2016/569¹⁴ of the European Data Protection Board, which includes a non-exhaustive list of measures that data controllers can take to comply with the accountability obligation in the event of a data breach: implementing and monitoring control procedures to ensure that all measures exist not only on paper but are also implemented and function in practice, establishing internal procedures, drafting a written and binding policy regarding data protection, and developing internal procedures for effectively managing and reporting security breaches.

55. In light of the above, the Dispute Chamber is of the opinion that the breach concerning personal data, the data breach in question, should have been reported to the GBA in accordance with Article 33 GDPR. The fact that the data breach was not reported to the GBA therefore constitutes a breach of Article 33.1 GDPR. This breach is not attributable to the respondent as they are not a data controller in the context of the notification procedure.

56. The Dispute Chamber then examines whether this breach concerning personal data was reported in a timely manner to the affected individuals in accordance with Article 34 GDPR.

57. According to Article 34 GDPR, the data controller must, in certain cases, not only notify the supervisory authority of a breach but must also

11 Recital 117 of the GDPR and CJEU Judgment of March 9, 2010, *Commission v. Germany*, C-518/07, ECLI:EU:C:2010:125, para. 23.

12 CJEU Judgment of October 6, 2015, *Schrems v. Data Protection Commissioner*, C-362/14, ECLI:EU:C:2015:650, para. 63.

13 Constitutional Court, Judgment No. 26/2023 of February 16, 2023, Roll Numbers: 7494, 7505, 7526, and 7606, para. B.30.6, available at <https://www.const-court.be/public/n/2023/2023-026n.pdf>.

14 Article 29 Working Party, Guidelines for the notification of personal data breaches under Regulation 2016/679, wp250rev.01.

Decision on the merits 171/2024 — 16/27

to also inform the affected individuals. This is the case when it is likely that a breach results in a high risk to the rights and freedoms of natural persons.

58. The threshold for notifying a breach to the affected individuals is therefore higher than that for reporting a breach to the supervisory authorities, and thus not all breaches that must be reported to the supervisory authority need to be reported to the affected individuals.

59. The respondent has reported the breach concerning personal data to the affected individuals. Regarding the timing of this notification to the affected individuals, the respondent argues that, given the circumstances, he informed the affected individuals as quickly as possible and as desired. To provide accurate information to the affected individuals, it was, according to the respondent, necessary to conduct a preliminary investigation to map the data leak. Based on the results of that investigation, the necessary communicative steps were taken without delay.

60. Early notification, without transparent information about the nature and extent of the incident, was,

according to the respondent, not justified. The analysis of the incident and coordination led to a clear and concise message in which the affected individuals (parents) were correctly informed, without minimizing the incident, within a week after the incident in question. On May 4, 2022, the respondent was aware of the incident; on May 9, 2022, the parents received the necessary information.

61. The respondent adds that no possible misuse (suspicious messages) was reported. The respondent therefore believes that he responded quickly and appropriately to the inquiries from the affected individuals (parents) that he received following the notification.

62. The question arises whether this notification to the affected individual occurred 'without delay,' as prescribed by Article 34 GDPR. Recital 86 of the GDPR states that the data controller must inform the affected individual of the breach concerning personal data without undue delay when that breach may result in high risks to the rights and freedoms of the natural person, so that they can take the necessary precautions. Such notifications to affected individuals should be made as soon as reasonably possible. For example, affected individuals should be informed without delay when there is an immediate risk of harm that needs to be mitigated. However, a longer notification period may be justified when appropriate measures must first be taken to remedy the security issue to avoid ongoing or similar breaches concerning personal data.

Decision on the merits 171/2024 — 17/27

63. The Dispute Chamber notes that, as previously mentioned, the respondent discovered the data leak on May 4, 2022. On May 4 and 5, 2022, investigations were conducted into the cause of the data leak by the software developer of the MeldJeAan platform. On May 5, 2022, the unsecured URLs were secured by Z3, after which they reported the data leak to the VTC on Friday, May 6, 2022. The notification to the affected individuals took place on Monday, May 9, 2022, at 18:47. The Dispute Chamber finds no elements in the respondent's conclusion that would justify this longer notification period, for example, that further (essential) steps were taken in the context of closing the data leak after May 5, 2022. The respondent does not provide arguments or elements indicating that there is a policy within LOP Gent Secundair regarding the effective management and reporting of breaches concerning personal data or other elements showing that a longer period for notification to the affected individual was necessary.

64. In this context, the Dispute Chamber also refers to the non-exhaustive list of measures that can be taken by the data controller to comply with the accountability obligation.

65. The Dispute Chamber is therefore of the opinion that the notification to the affected individuals did not occur without delay, resulting in a breach of Article 34.1 GDPR. This breach is not attributable to the respondent as he is not a data controller in the context of the registration procedure.

II.4. Article 35.1, 35.2, 35.3, and 35.7 of the GDPR

66. The Inspection Service finds that the respondent has violated Articles 35.1, 35.2, 35.3, and 35.7 GDPR as no DPIA was conducted by the respondent for the processing activities related to MeldJeAan.

67. The respondent argues that the application was put into use prior to the GDPR. The processing activities already existed at the time the GDPR became applicable. No substantial changes have been made to the application or procedure since the GDPR came into force. Therefore, no DPIA was conducted. Meanwhile, the data protection impact assessment has been carried out, which the respondent submits to the Dispute Chamber with his conclusions.

68. The Dispute Chamber reminds that, according to Article 35.1 GDPR, the data controller must carry out an assessment of the impact of the intended processing activities on the protection of personal data before processing, especially when the processing, particularly when new technologies are used, takes into account the nature, scope, context, and purposes.

Decision on the merits 171/2024 — 18/27

which likely entails a high risk to the rights and freedoms of natural persons. When a data protection officer is appointed, the data controller shall seek their advice when carrying out a DPIA (Article 35.2 GDPR).

As already stated in section II.1, the respondent should not be considered as the data controller for the processing of personal data in the context of the registration procedure.

69. The question arises whether a DPIA should have been prepared prior to the implementation of MeldJeAan. As the respondent also indicates in their conclusions, the decision to initiate a joint registration procedure was made in 2017. Due to a lack of financial resources to fund such a system, the respondent decided to utilize MeldJeAan, an application that had already been in use in Antwerp and in primary education in Ghent for several years. MeldJeAan was developed and put into use for Ghent primary education in 2009. The Dispute Chamber notes that the respondent does not contest that the processing in the context of MeldJeAan is of such a nature that a DPIA would be necessary. The respondent, on the other hand, states that they did not carry out a DPIA because the registration system was already in use before the GDPR became applicable.

70. The Dispute Chamber points out that several circumstances have changed since then that make the preparation of a DPIA necessary. First and foremost, the Dispute Chamber refers to legislative changes that have occurred since then. The registration system in secondary education was introduced by the Decree of the Flemish Parliament of May 17, 2019, amending the Decree on Primary Education of February 25, 1997, the Codex Secondary Education of December 17, 2010, and the Codification of certain provisions for education of October 28, 2016, regarding the right to enroll, which came into effect on September 1, 2022. As a result of the introduction of the registration system for Ghent secondary education, students who are to start in the first year of the first grade of secondary education are required to register via MeldJeAan. The individuals concerned have no choice but to register through this system, and if they wish to enroll in a school outside the registration system, this significantly reduces their chances of being admitted to their preferred school.¹⁵ This means that there is a new category of individuals whose personal data is processed via MeldJeAan, namely the students who wish to enroll in secondary education. This inevitably leads to a significant increase in the volume of personal data processed via MeldJeAan. It is therefore the responsibility of the data controller to verify whether the applicable security measures are sufficient to ensure compliance with the GDPR under these changed circumstances.

15 The website meldjeaansecundair.stad.gent states: "If you do not register your child, you can only enroll directly in a school with available places starting from May 14, 2024, at 9 AM. The number of schools with available places will be limited. Places will first be allocated to the children who have registered."

Decision on the Merits 171/2024 — 19/27

71.

In its conclusions, the respondent indicates that the circumstances at the time of the initial development of the application were completely different from today and that cybersecurity was not as relevant then. Since the respondent decided to use MeldJeAan, a system that was developed several years before 2017, he should have been aware that the circumstances regarding the security of personal data had changed and that the applicable measures concerning cybersecurity were potentially no longer aligned with the required level of data protection. In this context, the Dispute Chamber points out that MeldJeAan has been in effect for Ghent primary education since 2009. The drafting of a DPIA could have led to any issues regarding the security of MeldJeAan being identified.

72.

Given this imposed obligation for Ghent secondary education, along with the associated increase in the personal data to be processed from a new category of data subjects, the Dispute Chamber concludes that there are sufficient changed circumstances that required the drafting of a DPIA.

73.

Article 35.7 GDPR specifies what a DPIA must at least contain:

- a) a systematic description of the intended processing operations and the purposes of the processing, including, where applicable, the legitimate interests pursued by the data controller;
- b) an assessment of the necessity and proportionality of the processing in relation to the purposes;
- c) an assessment of the risks referred to in paragraph 1 to the rights and freedoms of data subjects; and
- d) the intended measures to address the risks, including safeguards, security measures, and mechanisms to ensure the protection of personal data and to demonstrate compliance with this

regulation, taking into account the rights and legitimate interests of the data subjects and other persons concerned.

The Dispute Chamber notes that initially no DPIA was drafted for the use of MeldJeAan in the context of the registration system for Ghent secondary education, although this was mandatory. In the meantime, a DPIA was drafted and submitted by the respondent to the Dispute Chamber. The Dispute Chamber finds that this DPIA is in accordance with the above provisions from Article 35 GDPR. Consequently, the Dispute Chamber also rules that there has been a historical breach of Articles 35.1, 35.2, 35.3, and 35.7 GDPR. These breaches are not attributable to the respondent since he is not a data controller in the context of the registration procedure.

Decision on the Merits 171/2024 — 20/27

II.5. Article 38.1 and Article 39 of the GDPR

74.

The Inspection Service notes in its inspection report that there is a breach of Articles 38.1 and 39 GDPR because the respondent cannot demonstrate that the data protection officer was effectively and timely involved in (i) the security of the processing of personal data in the context of MeldJeAan; (ii) the register of processing activities; and (iii) the assessment of the necessity of and, where applicable, the implementation of a DPIA.

75.

The Dispute Chamber reminds that Article 38.1 GDPR prescribes that the data controller ensures that the data protection officer is involved in a timely and proper manner in all matters relating to the protection of personal data.

76.

Based on Article 39.1 GDPR, the data protection officer must (a) inform and advise the data controller on his obligations under the GDPR and other Union or Member State data protection provisions and (b) monitor compliance with the GDPR, other Union or Member State data protection provisions, and the policies of the data controller or processor regarding the protection of personal data, including the allocation of responsibilities, awareness-raising and training of staff involved in processing, and relevant audits.

77.

The respondent argues that the application was put into use prior to the GDPR. At that time, the role of the data protection officer did not yet exist. As previously mentioned by the respondent, there was past uncertainty regarding the identity of the data controller, and no data protection officer was provided for the LOPs. According to AGODI, the school boards were always the data controllers in the context of the central registration system, although this view was not shared by all involved actors according to the respondent.

78.

The respondent points out that following the data breach, the school boards and their data protection officers were immediately involved. All security measures were discussed at meetings of the respondent in which the school boards were involved. As already mentioned under II.3, a DPIA was drafted that was submitted to the school boards and their data protection officers. Based on the feedback from these parties, the DPIA was finalized. This DPIA, along with the advice from the data protection officer, was submitted to the Dispute Chamber.

Decision on the Merits 171/2024 — 21/27

79. The respondent informs and raises awareness among the school boards to effectively and timely involve their data protection officer in future registration procedures and the processing of data through a registration system, the registration of processing activities, and the data protection impact assessment. The responsibilities will also be laid down in the agreement between joint controllers that the school boards will conclude.

80. The Dispute Chamber notes that over the past years, various authorities have taken different positions and provided advice regarding the processing responsibility concerning MeldJeAan. Meanwhile, clarity has been provided, and the school boards are considered as controllers in the context of MeldJeAan. The respondent indicates that it will play a sensitizing role towards the school

boards in future processing. The Dispute Chamber judges that there is insufficient evidence to conclude a violation of Article 38.1 and 39.1 GDPR on the part of the respondent regarding the processing in the context of MeldJeAan.

II.6. Article 30.1, Article 30.3, and Article 30.4 of the GDPR

81. The Inspection Service has determined that the respondent does not comply with the requirements of Article 30.1, 30.3, and 30.4 GDPR.

82. According to Article 30 of the GDPR, each controller is required to maintain a record of processing activities under its responsibility. Article 30.1 of the GDPR specifies the information that must be included in this record:

- a) the name and contact details of the controller and any joint controllers and, where applicable, of the representative of the controller and the data protection officer;
- b) the purposes of the processing;
- c) a description of the categories of data subjects and of the categories of personal data;
- d) the categories of recipients to whom the personal data have been or will be disclosed, including recipients in third countries or international organizations;
- e) where applicable, transfers of personal data to a third country or an international organization, including the identification of that third country or international organization and, in the case of transfers referred to in Article 49.1, second paragraph GDPR, the documents relating to the appropriate safeguards;
- f) where possible, the envisaged time limits for erasure of the different categories of data;
- g) where possible, a general description of the technical and organizational security measures referred to in Article 32.1 GDPR.

83. The record of processing activities must be maintained in writing, including in electronic form (Article 30.3 GDPR), and must be made available to the supervisory authority upon request (Article 30.4 GDPR).

84. In the context of the above obligations, the Inspection Service has identified the following shortcomings:

- a) An unapproved draft of the record of processing activities is not a record of processing activities, but a preparatory document. Nevertheless, the respondent must indeed maintain a record of processing activities and provide it upon simple request to the Inspection Service of the GBA;
- b) The description of the categories of data subjects and of the categories of personal data is incomplete (cf. Article 30.1, c) of the GDPR) as in the tabs of the not yet approved draft of the record of processing activities of the respondent, the categories of data subjects and of personal data are only briefly listed instead of being described. It is therefore unclear what is precisely meant;
- c) The respondent does not demonstrate that its not yet approved draft of the record of processing activities is current. The Inspection Service refers in this regard to the fact that the respondent states "Date of last modification: 26/09/2022" while the response via email to the Inspection Service was provided on 03/10/2022. Consequently, the Inspection Service received on 03/10/2022 the record of processing activities from the respondent that was last modified on September 26, 2022. Regarding these violations identified by the Inspection Service, the respondent argues that, concerning the registration system, the school boards are the controllers. The respondent therefore removes this processing from the record and clarifies that each school board has its own record of processing activities and that certain school boards have indicated that this processing is already included in their record. The respondent states that it will inform all involved school boards about the necessity to include the processing activities for the registration system in their record of processing activities.

85. The respondent provides more context to the findings of the Inspection Service and explains that for the registration system, the school boards are the controllers.

Decision on the Merits 171/2024 — 23/27

The respondent has therefore removed this processing from the register of processing activities and will inform the school boards about the necessity to update their own registers. Regarding point c) of the Inspection Service concerning the currency of the register of processing activities, the respondent states that this infringement is unclear since only 1 week has passed between the last adjustment of the register at that time and its submission to the Inspection Service. During this 1-week period, no

new adjustments were necessary.

86. The Dispute Chamber recalls the purpose of the register of processing activities. To effectively apply the obligations contained in the GDPR, it is essential that the data controller (and the processors) have an overview of the personal data processing activities they carry out. This register is primarily a tool to assist the data controller in complying with the GDPR for the various data processing activities they perform. The register makes the key characteristics visible. The Dispute Chamber is of the opinion that this processing register is an essential tool in the context of the aforementioned accountability obligation (Article 5.2 and Article 24 GDPR) and that this register underlies all obligations imposed on the data controller by the GDPR. In this context, the Dispute Chamber refers to part II.1 where it has established that the respondent is not the data controller in the context of the registration procedure.

87. To the extent necessary, the Dispute Chamber establishes the following regarding the infringements cited by the Inspection Service.

88. Regarding point a), the Dispute Chamber finds that all information, as required by Article 30.1 GDPR, is included in the register of processing activities as submitted by the respondent to the Inspection Service during the investigation, and therefore it does not establish any infringement in this regard. The Dispute Chamber emphasizes that a register of processing activities is a living document that must be continuously modified and updated.

89. Regarding point b) of the findings of the Inspection Service, the Dispute Chamber finds that neither the text of the GDPR nor the objectives of the GDPR prevent a listing of the categories of personal data and the categories of data subjects from being included in the register of processing activities or that a more detailed description would be necessary. Regarding the categories of recipients, the Dispute Chamber refers to a recommendation from the Data Protection Authority and the doctrine which states that while it is not necessary to list the individual recipients of the data, they can be grouped by category of recipients. *Mutatis mutandis*, this assertion can also be applied to the categories of personal data and data subjects. However, the Dispute Chamber points out that the filling out of the register of processing activities must always be evaluated on a case-by-case basis to determine whether the description or listing included is sufficiently clear and concrete. In the present case, the Dispute Chamber finds that the listings included in the register of processing activities were sufficiently concrete. According to the Dispute Chamber, there can be little doubt about the meaning of the listed elements, such as student and parents of the student, identification data, financial details, with clarification "received from a school allowance," data concerning education with clarification "educational level of the mother, report on special education, home language," and the national register number in the context of education.

90. Point c) of the findings of the Inspection Service concerns the currency of the register. The Dispute Chamber points out that the register of processing activities must be updated in accordance with the development and evolution of the activities of the relevant company or organization. If the data controller initiates a new processing activity or modifies an existing processing activity, the register of processing activities must be adjusted accordingly. Since the period between the last modification of the register of processing activities and its submission is limited to one week, and since there are no elements indicating that the register of processing activities would not have been current, the Dispute Chamber is of the opinion that no infringement has been demonstrated in this regard.

91. The Dispute Chamber finds that the (draft) register of processing activities was prepared in electronic and written form and that it was submitted to the Inspection Service when requested. The Dispute Chamber therefore finds that there is no infringement of Articles 30.1, 30.3, and 30.4 GDPR.

17 W. Kotschy, "Article 30: records of processing activities," in Ch. Kuner *The EU General Data Protection Regulation (GDPR)*, a commentary, 2020, p. 621.

Decision on the Merits 171/2024 — 25/27

III. Sanctions

93. From the case documents, the Dispute Chamber concludes that multiple violations of the GDPR have occurred. More specifically, there is a breach of Articles 5.1(f), 32.1, 32.2, in combination with 5.2, 24.1, and 25.1 GDPR, as well as violations of Articles 33.1, 34.1 GDPR, and finally of Articles

35.1, 35.2, 35.3, 35.7 GDPR.

94. According to Article 100 of the WOG, the Dispute Chamber has the authority to:

- 1° dismiss the complaint;
- 2° order the discontinuation of prosecution;
- 3° order a suspension of the ruling;
- 4° propose a settlement;
- 5° issue warnings and reprimands;
- 6° order compliance with the requests of the concerned party to exercise their rights;
- 7° order that the concerned party be informed of the security issue;
- 8° order that the processing be temporarily or permanently frozen, limited, or prohibited;
- 9° order that the processing be brought into compliance;
- 10° order the rectification, limitation, or deletion of data and notification thereof to the recipients of the data;
- 11° order the withdrawal of the recognition of certification bodies;
- 12° impose fines;
- 13° impose administrative monetary penalties;
- 14° order the suspension of cross-border data flows to another State or an international institution;
- 15° transfer the file to the Public Prosecutor's Office of Brussels, which will inform it of the outcome of the file;
- 16° decide on a case-by-case basis to publish its decisions on the website of the Data Protection Authority.

95. The Dispute Chamber notes that there was uncertainty regarding the identity of the data controller at the beginning of the registration procedure. Since the respondent does not establish the purpose and the essential means of the processing in the context of the registration procedure, the Dispute Chamber has determined that they should not be considered the data controller. Nevertheless, the respondent has taken responsibility following the data breach to bring the processing into compliance with the obligations arising from the GDPR, given the processing of (sensitive) personal data on a large scale. Given that the respondent does not need to submit a statement of opposition to the registry of the Market Court in accordance with Article 1034quinquies of the Ger.W.19, nor via the e-Deposit IT system of Justice (Article 32ter of the Ger.W.).

(get). Hielke HIJMANS

Chairman of the Dispute Chamber

5° the judge to whom the claim is submitted;

6° the signature of the applicant or their lawyer.

19 The application with its annex is sent by registered mail to the clerk of the court or filed at the registry in as many copies as there are parties involved.